

تقرير قرار الجاهزية

مجتمع السيطرة

مجتمع مهني عربي آمن – بوابة تأكيد البريد وموافقة المدير

مراجعة ما قبل فتح التسجيل العام

NO-GO

غير جاهز للإطلاق العام بعد

لا توجد حسابات إنتاج لاختبار البريد ودورة الموافقة وعزل بيانات عضو عن عضو؛ كما لم يُتحقق من webhook تنظيف الوثائق.

3 أكتوبر 2026 · إصدار الإنتاج المنشور

القرار مبني على فحص حي محدود، واختبارات محلية معزولة، لا على دورة مستخدم مكتملة.

1 الخلاصة التنفيذية

طُبِّقت على مشروع Supabase الحي بوابة الحساب التي تشترط تأكيد البريد ثم موافقة مدير، وفُصلت سياسات القراءة العامة عن دوال الصلاحية الداخلية. نُشرت نسخة GitHub Pages المحدثّة، وتؤكد وجود إعداد Supabase العام الصحيح في حزمة JavaScript الحية. لم يظهر وضع التجربة.

الحكم: NO-GO للإطلاق العام. السبب المحدد: قاعدة الإنتاج تحتوي حالياً صفرًا من مستخدمي Auth والملفات الشخصية؛ لذلك يستحيل إثبات تسليم البريد، انتقال الحساب من pending إلى approved، أو العزل الفعلي بين حسابين مستقلين.

المجال	الحالة	الدليل وحدّ الاستنتاج
بوابة الاعتماد	مطبقة	حالة pending ومشغّل الإنشاء والحراسة موجودة على الإنتاج؛ لم تُختبر بحساب حقيقي.
صلاحيات anon	مشددة	لا صلاحية تنفيذ لدوال المساعدة الحساسة المختبرة؛ عرض الكوتشات يستخدم security_invoker.
وثائق التوثيق	خاصة	bucket verification-private أظهر public=false؛ لم يختبر تنزيل متبادل بجلسات JWT.
وظائف Edge	منشورة	ACTIVE؛ الطلب غير المصرح أعاد 401، ولم يُنفذ حذف. سر التنظيف وwebhook غير متحقق منهما.
موقع Pages	منشور	الصفحات حُملت، والتسجيل غرض، ومسار الخلاصة والإدارة أعاد الزائر إلى الدخول.
اختبار حي بحسابين	غير منفذ	عدد مستخدمي Auth والملفات الشخصية = 0 وقت الفحص.

2 الأثر على الإطلاق

النسخة الحالية مناسبة لاستكمال اختبار محدود، لكنها لا تهرر فتح التسجيل للجمهور. لا يُعاد تشغيل supabase/setup.sql على المشروع القائم؛ ترحيل الاعتماد وتضييق anon سَجَلًا بالفعل. Google OAuth اختياري ومؤجل، وليس سبب قرار NO-GO.

3 أدلة التحقق على الإنتاج

3.1 قاعدة البيانات والصلاحيات

سُجلت `account_approval_gate_20261003 migration` بالإصدار `20261003200940`، ثم `anon_policy_scoping_20261003` بالإصدار `20261003201627`. قيمة `profiles.account_status` الافتراضية `pending` وغير قابلة لـ `NULL`. تأكد وجود `trigger` لإنشاء ملف جديد و `trigger` يحرس حقول الاعتماد. حُصر قرار المدير في RPC يتحقق من دور المدير وتأكد بريد الحساب المستهدف، ويكتب القرار في سجل المراجعة. لـ `anon` صلاحية `EXECUTE=false` على `is_account_approved`, `is_staff`, `is_active_group_member` و `is_group_owner`. عرض `public_coaches` مضبوط بخياري `security_barrier=true` و `security_invoker=true`، ويعيد فقط الكوتشات العامة المعتمدة. `bucket verification-private` خاص `(public=false)`.

أعاد Supabase Advisor صفراً من تحذيرات `SECURITY DEFINER` المتاحة لـ `anon` بعد التغيير. بقيت عشرة تحذيرات للدور `authenticated`؛ تشمل دوالاً تستعملها سياسات RLS أو RPCs الإشراف. راجعت الشيفرة للتحقق من ربطها بهوية المستدعي/الدور، لكن يبقى هذا تنبيهاً قابلاً للمراجعة، وليس ادعاءً بصفر تحذيرات أمنية.

3.2 واجهة الموقع والنشر

نجح `workflow` التطبيق [37151383910]، ونجح نشر [37151400542]. أعادت `login/`, `/register/`, `/`, `/feed` و `/admin/` استجابة `HTTP 200`. في المتصفح ظهر نموذج التسجيل؛ وعند فتح `/feed/` أو `/admin/` دون تسجيل، عاد الزائر إلى `login/`.

فحص الحزمة الحية أكد وجود عنوان مشروع Supabase والمفتاح العام اللذين قدمهما المالك، دون إدراج أي قيمة في هذا التقرير. أعاد فحص Console في متصفح Sandbox «لا يوجد إخراج». `gh variable list/set` رُفِض بـ 403، لكن ذلك لا ينفي الإعداد: الحزمة المنشورة نفسها تثبت القيم المستخدمة.

3.3 وظائف Edge

الوظيفتان `delete-account` و `cleanup-verification-files` في حالة `ACTIVE` (الإصدار 1). الحذف يتطلب JWT (`verify_jwt=true`)؛ وظيفة التنظيف تستخدم تحققاً مخصصاً من `x-cleanup-secret (verify_jwt=false)`. أُرسِل POST غير مصرح به فقط، وأعادت كل وظيفة 401. لم تُرسل طلبات مصادقة أو عملية حذف. لم يُتحقق من وجود `CLEANUP_WEBHOOK_SECRET` في البيئة البعيدة أو من إعداد `Database Webhook`.

4 ما اجتاز محلياً

نجحت أوامر `npm run typecheck`, `npm run build`, و `npm run lint`. طُبِق `setup.sql` واختبار `account_approval_smoke.sql` في قاعدة PostgreSQL مؤقتة ومعزولة؛ تحقق الاختبار من بداية الحساب `pending` بدور `member` فقط، ومنع الحساب `pending` من بيانات الأعضاء والتعديل الذاتي، وقصر قائمة المراجعة على المدير المؤهل، وتسجيل قرار المدير، وسحب التنفيذ المباشر من دوال المحفزات. انتهى الاختبار بـ `ROLLBACK`، ثم حُذفت قاعدة الاختبار. هذا اختبار محلي، وليس اختبار JWT/HTTP لخدمة الإنتاج.

5 بوابات الإطلاق المتبقية

1. أنشئ حساب المالك ببريد يملكه صاحبه، أكد البريد، ثم عيّن أول مدير من SQL Editor باستخدام دليل الإعداد. لا تشارك كلمة المرور أو JWT.
2. جهّز حسابي اختبار عاديين ببريديين تملكهما. أكد كليهما، وتحقق أن حالتهما تبقى pending وأن صفحة المراجعة وحدها متاحة قبل موافقة المدير.
3. بعد اعتماد حساب اختبار، اختبر جلسات JWT منفصلة أن العضو لا يقرأ رسائل أو طلبات توثيق أو وثائق الحساب الآخر، ولا يعدل دوره أو حالة اعتماده. اختبر أيضاً منع النشر العام وحد الرسائل اليومي.
4. اضبط SMTP موثوقاً واختبر رسالتي التأكيد والاستعادة فعلياً؛ قراءة إعداد Confirm Email لا تثبت وصول البريد.
5. اضبط CLEANUP_WEBHOOK_SECRET من لوحة Supabase وأنشئ Database Webhook لجدول public.verification_requests مع header اسمه x-cleanup-secret. اختبره بملف اصطناعي فقط.
6. اختبر delete-account بحساب تطوير مؤقت لا يحتوي بيانات حقيقية؛ لا تستخدم حساب المالك.
7. أبقِ Google OAuth مؤقتاً حسب القرار الحالي؛ ليس شرطاً لمسار البريد.

قرار الإطلاق: NO-GO حتى إغلاق البوابات 1-6.

الموافقة على فتح التسجيل تتطلب دليلاً مرئياً على البريد والتأكيد والمراجعة، واختبار عزل حي بحسابين؛ لا يكفي نجاح البناء أو PostgreSQL المحلي.

6 تنبيه أمني

وردت كلمة مرور لبريد في نص المحادثة السابق؛ ينبغي تغييرها مباشرة لدى مزود البريد وعدم إعادة استخدامها. لم تُدرج أي كلمة مرور أو مفتاح في هذا التقرير. لم تُجر عمليات حذف على الإنتاج، ولم تُستخدم بيانات صحية أو وثائق حقيقية.

المصادر الداخلية: [تقرير التدقيق الأمني]، [تقرير الأداء]، وسجلات GitHub Actions أعلاه. تاريخ الفحص: 3 أكتوبر 2026.